



WASA Y5_Q1/o6 | One State One GPS

Web Application Security Assessment Report

Application Deployment Name: One State One GPS
Department Name: Department of Mines & Geology

PwC, TPA Team

20/01/2023

WASA REPORT

One State One GPS, CEG Project

Cyber Security

Y5 Q1 (Jan-Mar 2023)

Table of Contents

1. Executive Summary	4
1.1. Introduction	4
1.2. Objectives and Scope	4
1.3. Report Circulation	4
1.4. Limitations	4
1.5. Approach and Methodology	5
1.6. Reading this Report	6
1.7. Summary of observations	7
2. Detailed Observation	8
2.1. Summary of Core Findings	8
2.2. Grey box Testing	8
3. Appendix: Risk Classification	14

1. Executive Summary

1.1. Introduction

Center for e-Governance, Government of Karnataka engaged PricewaterhouseCoopers Services LLP. (PwC) to perform web application security assessment of the web application “One State One GPS”. The overall objective of this assignment was to conduct an independent review of “One State One GPS” to identify any possible weakness and improvement areas which can be plugged with respect to the web application.

The security assessment was conducted by PwC to identify any gaps compared to the industry leading best practices for application security.

1.2. Objectives and Scope

The objective of this security assessment was to identify potential security weaknesses in the design and configuration of “One State One GPS” and provide both strategic and tactical recommendations to mitigate identified security risks.

The scope of the assessment includes the following:

Sr. No	Scope	Proposed Activity	URL
1.	One State One GPS	Web application security assessment: Grey box Testing	http://148.72.213.34/StateGpsWeb

1.3. Report Circulation

This report issued by PwC is provided solely for your internal use and benefit; only in connection with the purpose in respect of which the Services are provided. Unless required by law or otherwise specified in our proposal or engagement letter, you shall not provide our report (or a copy or extract from it) to any third party, publish it on a website or refer to us or the Services without our prior written consent. Unrestricted circulation of the report within CeG or to any other parties is associated with a risk of unauthorized personnel trying to exploit the reported weaknesses before they are plugged. We do not assume responsibility or liability for any losses suffered by CeG because of the circulation, publication, reproduction, or other use of this report contrary to the provisions of this section.

We may at our discretion grant or withhold our consent or grant subject to conditions rights for distribution of the report. In no event, regardless of whether consent has been provided, shall we assume any responsibility to any third party to whom our report is disclosed or otherwise made available.

1.4. Limitations

Given the inherent limitations in any system of control, the projection of any evaluation of the controls to future periods is subject to the risk that the control procedures may become inadequate because of changes in systems, conditions, or the degree of compliance with those procedures. The assessment is based on the current body of knowledge and not designed to detect all weaknesses in controls.

While every effort was taken to conduct the reviews in accordance with agreed parameters and procedures, the work done by the PwC team was based on the information received by them and the corresponding evidence provided to them. PwC could not factor in any information withheld from them or misrepresented to them. It is important to recognize that there are inherent limitations in our process as the review was based on generally accepted concept of sample testing and, therefore, subject to such limitations.

The test review was only at that instance point of time of assessment. The assessment is based on the vulnerabilities as mentioned in the RFP and not designed to detect all weaknesses in controls. Accordingly, changes in circumstances after our review could affect the findings outlined in this report. For assessment

we were provided a standalone application. Integration with other application is out of scope of this assessment.

Client provided us the staging environment for testing. Testing of Webservices and APIs were out of scope. Our review was carried out between 19th to 20th January, 2023.

1.5. Approach and Methodology

Based on our understanding of the scope of work we have adopted a customized approach to meet your requirements. The following paragraphs summarize our approach:

Reconnaissance	- Information Gathering - Application walkthrough - Plan for testing - Analysing overall application architecture
Vulnerability Assessment	- Automated Scanning - Searching for weakness that can be exploited - Test Case Preparation
Penetration Testing	- Manual Analysis of Vulnerabilities - Execute Manual Tests - Confirming the existence of vulnerability and how exploitable it is
Analyse Results & Prepare Report	- Analyse severity of vulnerability as per CVSS calculator - Prepare and submit reports with pragmatic recommendations.

PwC's vulnerability testing assessment aims to conduct numerous simulated attacks against the vulnerabilities and potential mitigations.

- 1. Reconnaissance:** We conducted a walk through to assess the scope of the security assessment and obtain the following information (but not limited to) to identify the potential attack vectors:
 - a. Entry points for the web application and services running on Servers
 - b. Protocols being used
 - c. Back-end technology including web server, framework, and development language
 - d. Banner grabbing (finger printing) to identify the running version of web server / application server and framework
 - e. View source of the web application to review the comments and metadata
- 2. Vulnerability Assessment:** We performed unauthenticated automated (wherever credentials are not available) scanning based on the scope using commercial and proprietary tools as applicable [including Burp Professional]. The automated scanning was conducted to identify any known vulnerabilities in the web application.
- 3. Penetration Testing:** Automated scanning is followed by a manual testing, to validate the vulnerabilities reported by automated scanning tool and assess other vulnerabilities not covered by the automated scanning tool.

4. **Analyze results and reporting:** We then analyzed the results both from automated scanning and manual inspection to identify the vulnerabilities applicable. The risk classification for each vulnerability was identified based on the likelihood of occurrence, impact, and level of access required to exploit a given vulnerability.

An exception based detailed report is prepared with the following:

- Description of the vulnerability
- Impact
- Risk Classification
- Recommendation including references, wherever required

1.6. Reading this Report

This report outlines our observations on “One State One GPS” and contains the following two sections:

Section I: Executive Summary – This section contains the background, project scope and summary of key findings.

Section II: Detailed Observations - This section contains detailed observations for security review of “One State One GPS”.

To facilitate adequate understanding, each exception identified as part of the review is accompanied by: Description (the details of the exception under consideration), Potential Impact (the impact on the security and the related concern) and Recommendation (potential solution definition for the identified exception).

Risk Categorization: To provide management with an indication as to the significance of risk involved and the priority with which the same needs to be addressed, all risks have been rated in accordance with the classifications given below:

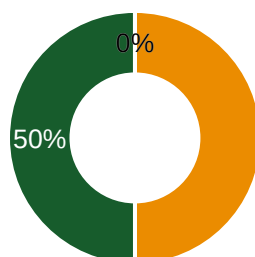
Severity	CVSS Score	Description
Critical	9.0 - 10.0	Weakness in controls that represent exposure to the organization or Risks that could seriously compromise the control framework, data integrity, and/or operational efficiency. These risks need to be addressed with utmost priority.
High	7.00 – 8.9	A potential weakness in controls, which could develop into an exposure. Or Issues that represent areas of concern and may impact controls. They should be addressed reasonably promptly.
Medium	4.0 – 6.9	Potential weaknesses in controls, which in combination with other weaknesses can develop into exposure. Suggested improvements not immediately/directly affecting controls.
Low	0.1 – 3.9	Vulnerabilities in the low range typically have very little impact on an organization's business. The exploitation of such vulnerabilities usually requires local or physical system access.

1.7. Summary of observations

The table below gives an idea of the risk-based distribution of the vulnerabilities found in the web application:

Serial No	Vulnerability Title	CVSS Score	Risk Rating
1	Directory Traversal	5.3	Medium
2	TLS 1.0 and 1.1 Enabled	5.1	Medium
3	Sensitive Information Disclosure	4.2	Medium
4	Missing Security Headers	3.6	Low
5	Server Version Disclosure	2.7	Low
6	Unencrypted Connection	3.8	Low

One State One GPS



■ Critical ■ High ■ Medium ■ Low ■ Informational

2. Detailed Observation

2.1. Summary of Core Findings

The findings reported have been categorized as Critical/High/ Medium/ Low/ Informational risk based on the impact on the affected web application. The tables below lists the vulnerabilities identified and the associated risk rating:

Serial No	Vulnerability	Risk Rating
1	Directory Traversal	Medium
2	TLS 1.0 and 1.1 Enabled	Medium
3	Sensitive Information Disclosure	Medium
4	Missing Security Headers	Low
5	Server Version Disclosure	Low
6	Unencrypted Connection	Low

2.2. Grey box Testing

2.2.1. One State One GPS WASA Detailed Report

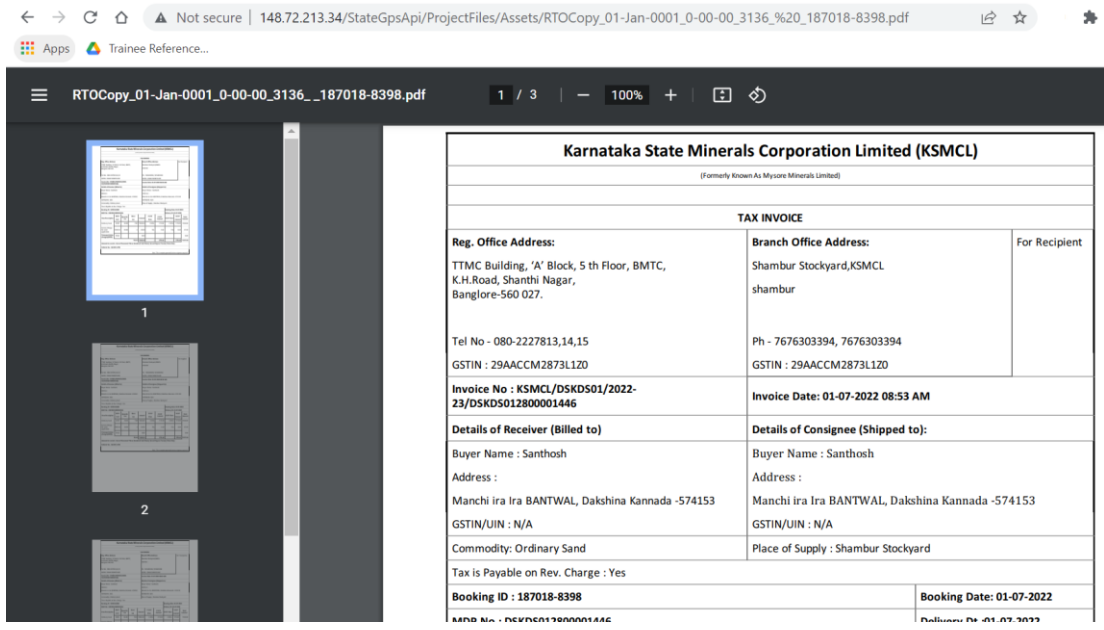
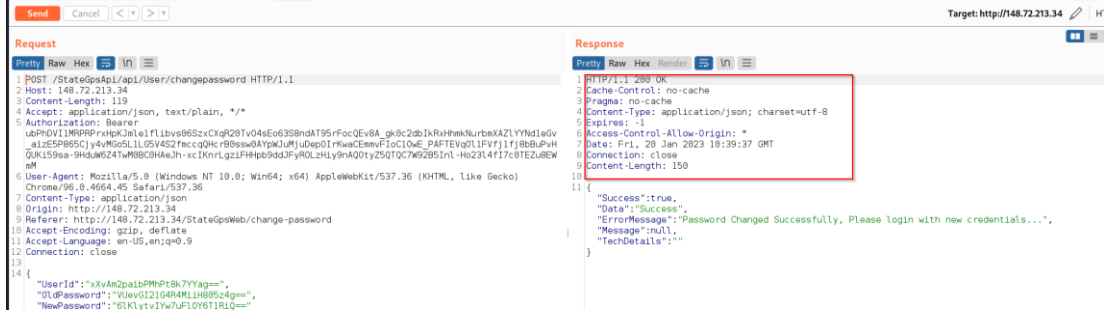
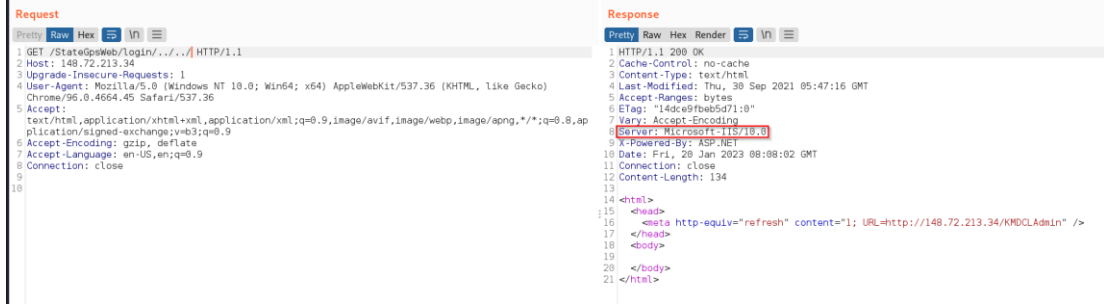
#	Observation	Description	Affected IP/URL	Severity	Implication s/ Impact	Remediation/ Recommendations
1	Directory Traversal	During the assessment it was observed that certain restricted directories can be accessed which contains files holding sensitive information.	http://148.72.213.34/StateGpsApi/ProjectFiles/	Medium	The attacker can get access of the sensitive information in the directories and can also gain access to the filesystem.	It is recommended to restrict the access of these directories to the normal users.
2	TLS 1.0 and 1.1 Enabled	During the assessment it was observed that the web server supports encryption through TLS 1.0 and 1.1 which are old versions of TLS.	http://148.72.213.34/StateGpsApi/	Medium	An attacker can exploit these to conduct attacks like Man-in-the-Middle and could also decrypt the	It is recommended to upgrade these servers to TLS 1.2 or higher.

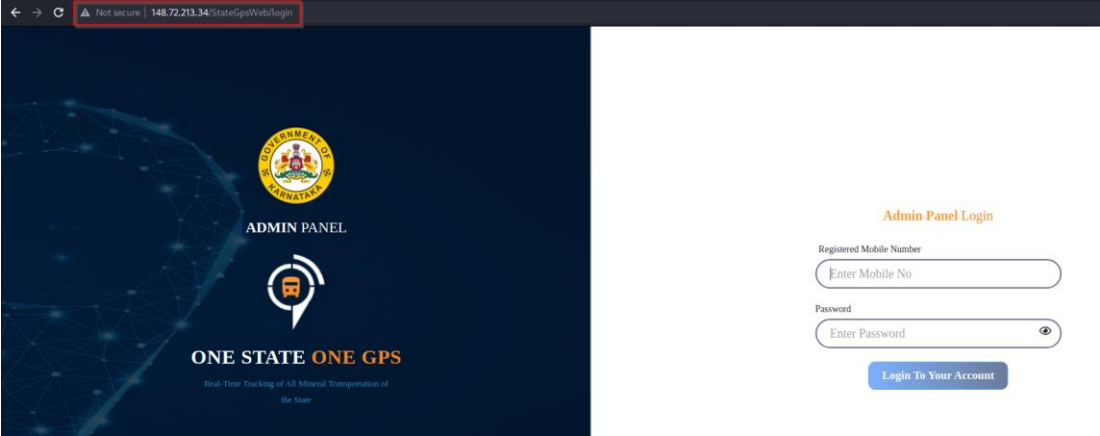
#	Observation	Description	Affected IP/URL	Severity	Implication s/ Impact	Remediation/ Recommendations
					communication.	
3	Sensitive Information Disclosure	During the assessment it was observed that the uploaded documents on the website concerned with the vehicles like RTO Permit and Vehicle RC can be accessed just by pasting the url without authentication.	http://148.72.213.34/StateGpsApi/	Medium	Incase of a successful brute force attack such documents can be accessed by the attacker and sensitive information can be gained.	It is recommended to give access to such documents only to authorized users.
4	Missing Security Headers	During the assessment it was observed that the certain security headers like X-XSS-Protection, X-Content-Type-Options, CSP header and HSTS header are not implemented.	http://148.72.213.34/StateGpsApi/	Low	These missing headers could lead to information disclosure and may affect the integrity of the data and they can be used to prevent attacks like XSS, clickjacking, man-in-the middle etc.	It is recommended to implement these headers into the web application.
5	Server Version Disclosure	During the assessment it was observed that the Microsoft-IIS/10.0 version is being disclosed.	http://148.72.213.34/StateGpsApi/	Low	An attacker can exploit vulnerability of a server if he knows the version	The version should not be disclosed

#	Observation	Description	Affected IP/URL	Severity	Implications/ Impact	Remediation/ Recommendations
6	Unencrypted Connection	During the assessment it was observed that the website can be accessed through HTTP.	http://148.72.213.34/StateGpsApi/	Low	When the website is accessed through HTTP connection then the traffic is sent over an insecure connection.	It is recommended to access the website only through a HTTPS connection.

2.2.2. Appendix: Web Application Security Testing Screenshots

	Vulnerability Type (Web App)	Evidence																				
1	Directory Traversal	← → ↻ 🏠 ⚠ Not secure 148.72.213.34/StateGpsApi/ProjectFiles/ Apps Trainee Reference... 148.72.213.34 - /StateGpsApi/ProjectFiles/ [To Parent Directory] <table><tr><td>1/2/2023 3:24 PM</td><td><dir> Assets</td></tr><tr><td>8/4/2021 3:30 PM</td><td><dir> Complaints</td></tr><tr><td>1/3/2023 10:48 AM</td><td><dir> DistrictServiceProvider</td></tr><tr><td>7/3/2021 5:13 PM</td><td><dir> GarageDetails</td></tr><tr><td>7/20/2022 10:46 AM</td><td><dir> GPSRermit</td></tr><tr><td>8/12/2021 4:16 PM</td><td>137493 GPSRermit.html</td></tr><tr><td>7/17/2021 6:37 PM</td><td><dir> HelpAndSupport</td></tr><tr><td>8/27/2022 2:03 PM</td><td><dir> MineralBlocks</td></tr><tr><td>8/27/2022 2:04 PM</td><td><dir> StockYards</td></tr><tr><td>6/9/2021 3:08 PM</td><td><dir> Vehicle_Owner_App</td></tr></table>	1/2/2023 3:24 PM	<dir> Assets	8/4/2021 3:30 PM	<dir> Complaints	1/3/2023 10:48 AM	<dir> DistrictServiceProvider	7/3/2021 5:13 PM	<dir> GarageDetails	7/20/2022 10:46 AM	<dir> GPSRermit	8/12/2021 4:16 PM	137493 GPSRermit.html	7/17/2021 6:37 PM	<dir> HelpAndSupport	8/27/2022 2:03 PM	<dir> MineralBlocks	8/27/2022 2:04 PM	<dir> StockYards	6/9/2021 3:08 PM	<dir> Vehicle_Owner_App
1/2/2023 3:24 PM	<dir> Assets																					
8/4/2021 3:30 PM	<dir> Complaints																					
1/3/2023 10:48 AM	<dir> DistrictServiceProvider																					
7/3/2021 5:13 PM	<dir> GarageDetails																					
7/20/2022 10:46 AM	<dir> GPSRermit																					
8/12/2021 4:16 PM	137493 GPSRermit.html																					
7/17/2021 6:37 PM	<dir> HelpAndSupport																					
8/27/2022 2:03 PM	<dir> MineralBlocks																					
8/27/2022 2:04 PM	<dir> StockYards																					
6/9/2021 3:08 PM	<dir> Vehicle_Owner_App																					
2	TLS 1.0 and 1.1 Enabled	Connected to 148.72.213.34 Testing SSL server 148.72.213.34 on port 443 using SNI name 148.72.213.34 SSL/TLS Protocols: <table><tr><td>SSLv2</td><td>disabled</td></tr><tr><td>SSLv3</td><td>disabled</td></tr><tr><td>TLSv1.0</td><td>enabled</td></tr><tr><td>TLSv1.1</td><td>enabled</td></tr><tr><td>TLSv1.2</td><td>enabled</td></tr><tr><td>TLSv1.3</td><td>disabled</td></tr></table> ONE STATE ONE GPS	SSLv2	disabled	SSLv3	disabled	TLSv1.0	enabled	TLSv1.1	enabled	TLSv1.2	enabled	TLSv1.3	disabled								
SSLv2	disabled																					
SSLv3	disabled																					
TLSv1.0	enabled																					
TLSv1.1	enabled																					
TLSv1.2	enabled																					
TLSv1.3	disabled																					

	Vulnerability Type (Web App)	Evidence
3	Sensitive Information Disclosure	 The screenshot shows a web browser displaying a PDF document. The document is a tax invoice from Karnataka State Minerals Corporation Limited (KSMCL) to Shambur Stockyard, KSMCL. The invoice details include Reg. Office Address, Branch Office Address, Tax Invoice details, and Buyer details.
4	Missing Security Headers	 The screenshot shows a web browser displaying the 'Response' tab of a network request. The response headers are listed, including 'Cache-Control: no-cache', 'Pragma: no-cache', 'Content-Type: application/json; charset=utf-8', 'Expires: -1', 'Access-Control-Allow-Origin: *', 'Date: Fri, 20 Jan 2023 18:39:37 GMT', 'Connection: close', and 'Content-Length: 150'.
5	Server Version Disclosure	 The screenshot shows a web browser displaying the 'Response' tab of a network request. The response headers are listed, including 'HTTP/1.1 200 OK', 'Cache-Control: no-cache', 'Content-Type: text/html', 'Last-Modified: Thu, 30 Sep 2021 05:47:16 GMT', 'Accept-Ranges: bytes', 'ETag: '14dce9fbeb5d71:0'', 'Vary: Accept-Encoding', 'Server: Microsoft-IIS/10.0', 'X-Powered-By: ASP.NET', 'Date: Fri, 20 Jan 2023 08:08:02 GMT', 'Connection: close', 'Content-Length: 134'.

	Vulnerability Type (Web App)	Evidence
6	Unencrypted Connection	

3. Appendix: Risk Classification

The risk ratings assigned to each finding in this report are based on 3 dimensions – Likelihood, Impact, and Level of access required. These are defined below:-

Likelihood	High/ Critical	Attacker can use existing tools to exploit the vulnerability by following prescriptive instructions and without knowledge of coding/platforms. Target can be exploited directly. Finding assists with exploitation of or is linked to other high or critical risk findings.
	Medium	Attacker must have knowledge of coding/platforms and may require customization of tools (e.g., batch scripts, shell scripts, Metasploit module customization) to exploit the vulnerability. Exploitation of target may require setup of additional infrastructure or processes.
	Low	High level of skill required to exploit. Attacker must develop their own tools or processes (e.g., custom written exploit code) to successfully exploit the vulnerability. Publicly available exploits were not identified. Exploitation of target requires setup of additional infrastructure or processes (e.g., Spear Phishing).
Impact	Severe	Vulnerability may lead to widespread administrator access to multiple materially sensitive systems (e.g., Enterprise Administrator), or access to the internal network from the Internet.
	Major	Vulnerability may lead to immediate access to sensitive or materially sensitive data, or highly privileged access to critical business systems, or a severe and extended disruption to critical business systems or operations, with impact to many users or sites.
	Moderate	Vulnerability may lead to access to sensitive data, or privileged access to critical business systems, or partial disruption to critical business systems or operations, with impact to some users or sites.
	Minor	Vulnerability may lead to: Access to non-sensitive data, or Access to non-critical business systems, or Disruption to non-critical business systems or operations, with limited impact to users/sites.
Level of access required ¹	Insignificant	Information disclosure of non-sensitive enticement information (e.g., IP addresses, hostnames, system information) with no direct impact to availability.
	Privileged	Privileged user (e.g., administrator).
	Non-privileged	General user (e.g., domain user).
	Internal Anonymous	Unauthenticated user with access to the internal network.
Level of access required ¹	External Anonymous	Unauthenticated Internet user (includes web applications that allow self-registration).

¹ Minimum level of access required to exploit the vulnerability

To determine the final risk rating for a reported finding, a score must be assigned to each of these 3 dimensions, as per below:

Impact

		Insignificant	Minor	Moderate	Major	Severe
Likelihood	Critical	1	2	3	4	5
	High	1	2	3	4	5
	Medium	1	2	3	4	5
	Low	1	1	2	3	5

Level of access required	
Privileged	A
Non-privileged	B
Internal Anonymous	C
External Anonymous*	D
*Includes self-registration	

This will result in a number (1-5) and a letter (A-D). Combining these gives the final risk rating, as indicated by the below matrix.

	1	2	3	4	5
A	Info	Low	Medium	Medium	High
B	Info	Low	Medium	High	High
C	Low	Low	Medium	High	Critical
D	Low	Medium	High	High	Critical

The final risk ratings are defined as follows:

Informational	No immediate risks to the environment were identified as part of the testing. Findings are informational only.
Low	No immediate action required. Remediation items can be implemented during the next scheduled change window.
Medium	Action should be taken to address findings in a timely manner. Out of cycle change and compensating controls may be required.
High	Urgent action should be taken to address findings.

Note: The above matrices are intended to be used as a guide only in determining the appropriate risk rating for a particular vulnerability. Other factors may need to be considered when weighing up the final risk rating, such as the number of servers affected by the vulnerability, nature of systems affected (e.g., Production, Development, and Test), and nature of data accessed or disclosed.

---End of Document---

Data Classification: DC2 (Confidential)

All images in this presentation are protected by copyright, trademark, patent, trade secret and other intellectual property laws and treaties. Any unauthorised use of these images may violate such laws and shall be punishable under appropriate laws. Our sharing of this presentation along with such protected images with you does not authorise you to copy, republish, frame, link to, download, transmit, modify, adapt, create derivative works based on, rent, lease, loan, sell, assign, distribute, display, perform, license, sub-license or reverse engineer the images. In addition, you should desist from employing any data mining, robots or similar data and/or image gathering and extraction methods in connection with the presentation.

In this document, PwC refers to PricewaterhouseCoopers Private Limited (a limited liability company in India having Corporate Identity Number or CIN : U74140WB1983PTC036093), which is a member firm of PricewaterhouseCoopers International Limited (PwCIL), each member firm of which is a separate legal entity.

© 2022 PricewaterhouseCoopers Private Limited. All rights reserved.

GG/June 2022 – M&C 20377